

Assignment on Lectures 1 and 2

1. PROBLEMS:

1.1 [20 POINTS]

Consider a student information system (SIS) in which students provide a university student number (USN) and a card for account access. Give two examples of each CIA triad requirements (**confidentiality, integrity, and availability**) associated with the system and, in each case, indicate the degree of the importance of the requirement.

1.2 [20 POINTS]

Consider the following general code for allowing access to a resource:

```
DWORD dwRet = IsAccessAllowed(...);  
if (dwRet == ERROR_ACCESS_DENIED) {  
    // Security check failed.  
    // Inform user that access is denied.  
} else {  
    // Security check OK.  
}
```

- a. Explain the security flaw in this program.
- b. Rewrite the code to avoid the flaw.

Hint: Consider the design principle of fail-safe defaults.

1.3 [10 POINTS]

Develop an attack tree for gaining access to the contents of a physical safe.

1.4 [15 POINTS]

Consider a company whose operations are housed in two buildings on the same property: one building is headquarters, the other building contains network and computer services. The property is physically protected by a fence around the perimeter. The only entrance to the property is through a guarded front gate. The local networks are split between the Headquarters' LAN and the Network Services' LAN. Internet users connect to the Web server through a firewall. Dial-up users get access to a particular server on the Network Services' LAN. Develop an attack tree in which the root node represents disclosure of proprietary secrets. Include physical, social engineering, and technical attacks. The tree may contain both AND and OR nodes. Develop a tree that has at least 15 leaf nodes.

1.5 [15 POINTS]

A small e-commerce company experiences a security incident. An attacker exploits a known software bug in their web server to gain access and then deletes all the product databases. Based on the terminology in the lecture, define and identify the following:

- a) The primary Asset(s) involved.
- b) The Vulnerability.
- c) The Threat.
- d) The Attack and indicates its category.
- e) A Countermeasure that could have helped and indicates its category.